MAJO BRIDGE TECHNOLOGIES AND EVENTS PLC

MaJo e-School Bridge (MayaBela) · INSA asset registration attachment

Requirements Documentation (Software Requirements Specification)

Software Requirements Specification (SRS)

Product: MaJo e-School Bridge (MayaBela)
Multi-tenant school information system

Document number	MB-SRS-001
Version	1.0 · 10 November 2026 · East Africa Time (Africa/Nairobi)
INSA portal field	Requirements Documentation (SRS) — defines intended system behaviour and requirements; used to identify critical functionality, user roles, and required security controls.
Owner	Cyber Security Officer / Engineering, Majo Bridge Technologies and Events PLC
Classification (CMCSRS Annex B)	CONFIDENTIAL — describes controls over children's records. Do not publish credentials.
Related records	CSMS-POL-001, CSMS-AST-001, CSMS-CMCSRS-001, MODULE_PERMISSION_MATRIX, Guideline evaluation R3, CMCSRS v2.0 evaluation

This SRS states **intended** behaviour of the submitted product. It is not an INSA certificate, not a pentest letter, and not proof that the live hosted project already equals every hardened migration. Live SQL is applied only in a notified window so classrooms stay up.

1. Purpose and scope

1.1 Purpose

MaJo e-School Bridge is a Flutter web and mobile ERP for Ethiopian schools. One deployment serves many school tenants. Each school's students, staff, marks, fees, and files must stay inside that school. This document is the requirements baseline for INSA asset registration: what the system is for, who may use it, which functions are critical, and which security controls are required.

1.2 In scope

- School information: students, classes, attendance, homework, grades, admissions, parent links.
- Operations: fees, inventory/procurement, HR/staff accounts, transport (buses, drivers, passenger lists, live position of the assigned bus).
- Sensitive collections: health, counselling, safeguarding — restricted staff only.
- Identity: school login, JWT school and role claims, optional/required MFA by role.
- Platform owner console (provision schools; not a classroom role).
- Hosted persistence (Postgres `app_documents`, storage buckets, Edge Functions) and dedicated/on-prem instances for schools that cannot share the hosted tenancy.

1.3 Out of scope

- A school's own campus CCTV, IoT, or blockchain — not objects of this product.
- National PKI, INSA-approved proprietary crypto, or customer-managed disk keys on the current hosted database (operator residual; see CSMS-SUP-001).
- Forcing MFA on classroom teachers, parents, students, or drivers (would lock live lessons).

2. Intended system behaviour

The system shall behave as a **multi-tenant school ERP with need-to-know access**:

1. **Tenant isolation.** Every persistent row carries `school_id`. A JWT from School A cannot read or write School B. Isolation is enforced in the database (row-level security), not only in the client.
2. **Role-based desks.** After login, the user sees modules for their role (teacher classroom, registrar, finance, driver, parent, student, platform owner). The client must not be the only gate: denied writes return an error and must not dump the whole school.
3. **Classroom continuity.** Ordinary teachers write attendance, homework, and class notices for **their assigned classes**. They shall not receive payroll, HR, or whole-school children's files they do not manage.
4. **Finance integrity.** Recording that a fee is paid is a finance/cashier function. Homeroom shall not silently mark paid.
5. **Admissions.** Creating or changing admission applications through the privileged registry path is a registrar (or equivalent) function, not every staff JWT.
6. **Transport need-to-know.** A driver sees students whose `transportId` matches that driver's `busId`, and may publish GPS/scans for that bus only.
7. **Public surface.** The login page has no JWT. Only school logos (branding bucket) are public. Student files stay under `schools/<school_id>/`.
8. **Availability of teaching.** Security changes that could stop a live school are applied on staging, then in a notified production window.

3. User roles

Identity is a username + role + school. The JWT stores school and role in `app_metadata` only (not in user-editable metadata). Staff desks use the templates in `StaffRoles` (a school may add a titled copy of a template; permissions stay those of the source template unless the school owner changes them in Role Settings).

3.1 External / community roles

Role	Intended access	Must not
Parent	Linked child: attendance, homework, published materials, selected notices, fee view where provided	Other children; staff HR; other schools
Student	Own record: timetable, homework, own grades where published	Other students' PII; staff modules
Driver	Own bus passenger list; own GPS and scan publish	Walkers; other buses; school-wide registry

3.2 School staff templates

Role (English)	Critical functions
School Owner / Full Access	Tenant administration; role titles; cannot be granted by a teacher to themselves
School Admin (login role `admin`)	School-wide operations; privileged MFA required
School Board	Oversight: view students, staff, grades, reports, audit — not day-to-day payroll write
General Manager / Deputy GM	Cross-department view; approvals (grades, transfers, purchase/issue)
Principal / Vice Principal	Academic leadership; classes; announcements; VP may span more operational modules
Section Director	Class/subject/timetable; transfer *requests* (approval is VP/leadership)
Quality Assurance	Observations, QA findings, reports
Student Affairs	Student support, parent links, transfers create, announcements
Registrar	Student registry, promotions, admissions (privileged path)
Finance Manager (accountant)	Fees, payments, finance reports; privileged MFA required
Human Resource	Staff accounts; selected transport admin
Librarian	Learning materials and access
Procurement Manager	Purchase requests, suppliers, goods entry
Store Keeper	Receive / issue / adjust stock
Transport Head	Buses, drivers, student–bus assignment
Teacher (login role `teacher`)	Assigned class: attendance, homework, marks, class notices. MFA optional
Staff (generic)	Baseline desk (directory, support) without classroom or finance write

3.3 Platform role (vendor, not a school desk)

Role	Intended access	Must not
Platform owner	Provision / suspend schools; branding; PIN-gated owner console	Use a school teacher JWT to administer the platform; store the service-role key in the app

Classroom teachers, parents, students, and drivers are **not** designated security-assessment positions. DSAPs (CSO, platform operators, hosted-project administrators) are listed in CSMS-AST-001.

4. Critical functional requirements

Critical = required for the school's mission or for protection of children's data. IDs are stable for INSA traceability.

ID	Requirement	Priority
FR-01	Authenticate a user to exactly one school and role; issue JWT with school and role in `app_metadata`.	Critical
FR-02	Maintain a student registry (identity, class, links to parents) scoped to that school.	Critical
FR-03	Record attendance and homework for the teacher's assigned class.	Critical
FR-04	Record and publish grades; grade audit trail shall be append-only (no silent rewrite of history).	Critical
FR-05	Collect admission applications; privileged registry writes restricted to registrar (or equivalent).	Critical
FR-06	Manage fees and record payments as a finance function.	Critical
FR-07	Assign students to buses; driver views only assigned passengers; driver publishes only own bus GPS/scans.	Critical
FR-08	Restrict health, counselling, and safeguarding collections to authorised student-affairs / safeguarding roles.	Critical
FR-09	Let parents and students see only linked/self records.	Critical
FR-10	Deliver school notices and in-app notifications within the school audience.	High
FR-11	Show public school logo on login without exposing student files.	High
FR-12	Optional Maya Assistant: counts-only live context; refuse health, safeguarding, passwords, and children's IDs.	Medium
FR-13	Platform owner can create a school tenant without mixing its data into another tenant.	Critical
FR-14	Support a dedicated / on-prem instance for a school whose TOR forbids the shared hosted tenancy.	High

5. Required security controls

These controls are requirements of the product CSMS (people / process / technology). They map to INSA Guideline R3 and to applicable CMCSRS v2.0 clauses. Operator residuals (local CSP, INSA accreditation) are listed in §7 and are **not** claimed as implemented.

ID	Control	How it is required to work
SR-01 Tenant RLS	Row-level security on `app_documents`	SELECT/INSERT/UPDATE/DELETE only when `school_id` matches JWT school. Anon has no document policy.
SR-02 Role write-guard	Server-side write policy by role and collection	Teachers: class-scoped academic writes. Payroll/HR denied to classroom teachers. Fees paid-status is finance. Admissions privileged path is registrar.
SR-03 Driver need-to-know	Student SELECT + transport writes	Driver reads own-bus students only; cannot overwrite another bus's GPS.
SR-04 JWT claims	`app_metadata.schoolId` / role	Database helpers ignore user-editable metadata.
SR-05 Client key	Anon key in the app	Not a secret. Service-role key must never ship in Dart/HTML/mobile. RLS is the boundary.
SR-06 Privileged MFA	Second factor	Required for School Admin and Finance (accountant). Teachers, principals, parents, students, drivers: optional. Login still succeeds; Settings prompts enrolment for privileged roles.
SR-07 Auth hardening	Password, PIN, rate-limit	School passwords bcrypt, minimum length 10. Platform PIN PBKDF2-SHA256 (210,000 iterations). Login rate-limit 8 / 15 minutes per username+role+school.
SR-08 Storage	Path isolation	Probes and student files under `schools/<id>/`. Public `school-branding` is logos only.
SR-09 Audit	Append-only grade audit; school audit actor stamp	Grade history cannot be quietly rewritten. Audit actor is the authenticated principal, not a client-supplied name.
SR-10 Edge inventory	Every Edge Function has a declared auth mode	CI fails if a function folder is added without an auth mode. Registry writes use an explicit policy because they use the service role.
SR-11 AI	DPIA for Maya Assistant	No names in live context. Refuse safeguarding/health/passwords/IDs. If the AI key is unset, the ERP still works.
SR-12 CAAT	Automated control tests	Local Postgres replay of migrations (role-by-role, driver need-to-know, two-school isolation). Flutter tests for privileged MFA and 403 behaviour. Deno policy tests. Production project is never the RLS isolation target.
SR-13 Change window	No mid-day production SQL	Staging then notified production apply so attendance and parent login keep working.
SR-14 Incident	CSMS-IRP-001	Contain without wiping evidence. Report confirmed incidents to Ethio-CER2T via the CSO. Do not paste student rows into tickets.

6. Information assets and classification

Labels follow CMCSRS v2.0 Annex B (four levels only).

Asset	Annex B	Why it is critical
Student identity, marks, attendance, health, safeguarding	CONFIDENTIAL	Children's data; FR-02–FR-08

Asset	Annex B	Why it is critical
Staff HR / payroll in the ERP	CONFIDENTIAL	Need-to-know vs classroom teachers
Service-role key	CONFIDENTIAL	Bypasses RLS if leaked; SR-05
JWT school/role claims	CONFIDENTIAL	Tenant boundary; SR-04
Student files (`school-files`)	CONFIDENTIAL	SR-08
School logos (`school-branding`)	PUBLIC	Login page; FR-11
Anon / publishable key	PUBLIC	Compiled into the client by design

SECRET / TOP SECRET are not claimed for school registers unless INSA directs a higher label.

7. Assumptions, dependencies, residuals

- Each customer school is the **controller** of its children's data; MaJo Bridge is the **processor** for the ERP.
- Hosted Postgres, Auth, Storage, and Edge Functions are a sub-processor (see CSMS-SUP-001). Disk encryption keys on that host are the supplier's — operator residual against CMCSRS §6.29.f.
- Governmental / key-private locally licensed cloud (§6.29.k) is not claimed for the shared hosted project. Dedicated/on-prem is the path for schools that cannot share it.
- This SRS does not replace INSA accreditation or an annual compliance letter.

8. Verification

Requirements FR-01–FR-09 and SR-01–SR-12 are verified in source by CAAT and CI (local Postgres role tests, driver 9/9, two-school 7/7, Flutter privileged-MFA tests, Deno Edge inventory). Live production is not mutated by this document.

Prepared by (Engineering / CSO)

Majo Bridge Technologies and Events PLC · 10 November 2026, East Africa Time

For INSA asset registration

Attachment to field: Requirements Documentation (SRS)